

SECURITY INCIDENT RESPONSE USE CASES

Step-by-Step Triage Playbook for Blue Teams

AD, WINDOWS, EMAIL, EDR

BY

ASHWATHY KRISHNA R
ANANDHU S

How This Document Can Be Used

This guide is designed to assist **Security Analysts, Incident Responders, and SOC Teams** in identifying, analyzing, and mitigating common security threats.

It provides:

- Clear triage procedures
- Detection indicators
- IOC references
- MITRE ATT&CK mappings
- Recommended containment actions

It can be used in:

- Daily SOC operations
- Internal threat-hunting playbooks
- Blue team training scenarios
- Post-incident review documentation



Key Terms and Meanings

Term	Meaning
IOC	Indicator of Compromise – evidence such as IPs, hashes, domains, etc.
MITRE ATT&CK	Framework categorizing tactics, techniques, and procedures used by attackers
AD	Active Directory – Microsoft's identity and access management service
SIEM	Security Information and Event Management – used for centralized log analysis
MFA	Multi-Factor Authentication – additional authentication beyond passwords
BEC	Business Email Compromise – social engineering attack via email impersonation
LOLBin	Living-Off-the-Land Binary – legitimate tools used maliciously by attackers
EDR	Endpoint Detection and Response – security tools that detect endpoint threats

Table of Contents

1. Authentication & Active Directory (AD)

- Case 1: Brute Force or Password Spraying
- Case 2: Privilege Escalation – Group Membership
- Case 3: Impossible Travel Login
- Case 4: Dormant Account Usage

2. Windows/Linux Endpoints

- Case 1: Malicious Process Execution
- Case 2: Registry Modification Alerts
- Case 3: Suspicious PowerShell or CMD Usage
- Case 4: LOLBins Execution

3. Email Security

- Case 1: Phishing Attempt
- Case 2: Malware in Attachments
- Case 3: Business Email Compromise (BEC)

4. Endpoint Detection & Response (EDR)

- Case 1: Lateral Movement
- Case 2: Persistence Mechanisms
- Case 3: Credential Dumping Tools

Authentication & Active Directory (AD)

Case1:

Brute Force or Password Spraying Detection (Active Directory)

Detection Indicator: Multiple failed login attempts to AD or VPN.

Step-by-Step Triage (Security Analyst View):

1. Confirm the Alert:
 - Validate via AD Sign-in Logs, Event ID 4625 (failed logons).
 - Filter by IP address, username (UPN), and timestamp.
2. Identify Scope:
 - Highlight accounts and IPs with repeated failures.
 - Identify any successful logins (Event ID 4624) that follow failed attempts.
3. Correlation:
 - Cross-reference with Entra ID Protection and Audit Logs.
 - Check account lockouts or Smart Lockout triggers.
4. Threat Intelligence Check:
 - Investigate source IPs using AbuseIPDB, VirusTotal, or MDTI.
5. Check MFA & CA Enforcement:
 - Review if MFA is enforced and CA policies are effective.

Containment:

- Disable affected accounts
- Reset passwords
- Enforce MFA for targeted users
- Review lockout threshold and smart lockout behavior

IOCs to Look For:

Type	Example / Detail
IP Address	IPs with >20 failed logins in 5 minutes (AbuseIPDB/VirusTotal flagged)
Username	Repeated targeting of specific UPNs (e.g., admin@corp.com)
Geolocation	Logins from suspicious or unexpected regions

Time-based	High-volume attempts in off-business hours
Log Result	Event ID 4625 (failure) without subsequent 4624 (success)
Pattern	One IP hitting multiple usernames (spraying), or one username hit by multiple IPs (brute force)

MITRE Techniques:

- T1110 – Brute Force
- T1110.001 – Password Guessing
- T1110.003 – Password Spraying

Log Sources – Brute Force or Password Spraying Detection

Source	Details
Windows Security Logs	Event ID 4625 (Failed Logins), 4624 (Successful Logins)
Active Directory Logs	Account lockouts, password policy enforcement
Microsoft Entra ID Sign-in Logs	Failure reasons, user details, IP addresses
Audit Logs	Any changes in password or lockout settings
SIEM	Aggregated correlation across AD, VPN, and endpoint sources

Case 2:

Privilege Escalation – High-Privilege Group Membership (Active Directory)

Detection Indicator: A user account is added to privileged groups like Domain Admins, Enterprise Admins, or custom security groups.

Step-by-Step Triage (Security Analyst View):

1. Confirm the Alert:

- Review AD logs for Event ID 4728 (user added to a security-enabled global group).
- Confirm if the group is highly privileged (e.g., Domain Admins).

2. Identify Initiator and Source:

- Who performed the action? Review the subject fields in the event log.
- Determine workstation or IP address used for the operation.

3. Validate Authorization:

- Check if the group addition was part of a legitimate change request.
- Review ticketing system or change logs.

4. Correlate Logs:

- Analyze recent login activity of the involved user(s).
- Check for lateral movement, login times, and access to sensitive systems.

5. Cross-Reference with Threat Intel:

- Determine if source IPs or user agents are suspicious.
- Check for repeat behavior from same source.

Containment:

- Immediately remove the user from the privileged group if unauthorized
- Disable account temporarily if malicious activity is suspected
- Audit all changes to group memberships in the timeframe
- Alert relevant teams and document the incident

IOCs to Look For:

Type	Example / Detail
User Account	Username added to Domain Admins or similar group
Workstation	Source system from where group addition was made
Time	Unusual or after-hours group modification
Event ID	Event ID 4728 in Security logs
Source IP	Unknown or foreign IP address used for AD modification
Pattern	Repeated admin group modifications in short span

MITRE Techniques:

- T1078 – Valid Accounts
- T1484.001 – Group Policy Modification

Log Sources – Privilege Escalation – High-Privilege Group Membership

Source	Details
Windows Security Logs	Event ID 4728/4729 (Group membership changes)
AD Audit Logs	Group modification and access control list changes
PowerShell Logs	Commands used to modify group memberships
SIEM	Privilege escalation correlation and anomaly patterns



Case 3:

Login from Impossible Travel Locations

Detection Indicator: A user logs in from two geographically distant locations within a short time frame, making legitimate travel physically impossible.

Step-by-Step Triage (Security Analyst View):

1. Confirm the Alert:

- Review Microsoft Entra ID sign-in logs or SIEM alerts triggered by impossible travel detection rules.
- Note the timestamp, user account, IP addresses, and locations involved.

2. Analyze Sign-in Context:

- Verify user agents, device IDs, and sign-in methods for both logins.
- Check for use of VPN, proxy, or cloud SSO providers.

3. Cross-Check Known Devices & IPs:

- Compare login IPs against known corporate IPs, VPN gateways, and previously associated devices.
- Review MFA behavior: was it prompted or bypassed?

4. Validate with User:

- Reach out to the user for confirmation.
- Confirm whether travel or remote access occurred using authorized tools.

5. Correlate with Other Logs:

- Check if suspicious sign-ins are followed by privileged actions, file access, or group modifications.

Containment Actions:

- Re-authenticate user using strong MFA.
- Invalidate sessions across devices for the user.
- Enforce conditional access policies for geo-location restrictions.
- Monitor for further anomalous behavior over the next 24-48 hours.

IOCs to Look For:

Type	Example / Detail
IP Address	One IP from UAE, another from the US within 10 minutes
Location	Countries with no direct flights or extreme distance/time gap
Pattern	Same user logging in from multiple countries rapidly
Device ID	New/unrecognized device IDs compared to baseline

MFA Behavior	Logins that skipped or failed MFA checks
Risk Score	Entra ID risk classification: high or medium

MITRE ATT&CK Techniques:

- T1078 – Valid Accounts
- T1021.001 – Remote Services (RDP/SSH/VPN)
- T1530 – Data from Cloud Storage

Log Sources – Login from Impossible Travel Locations

Source	Details
Microsoft Entra ID Sign-in Logs	Location metadata, device ID, MFA result
Azure AD Risk Events	Impossible travel alerts and risk scores
Conditional Access Logs	Policy enforcement or bypass status
VPN Logs	Tunnel connection validation
SIEM	Geographic anomaly correlation



Case 4:

Disabled or Dormant Account Usage

Detection Indicator: Authentication or activity from an account that was disabled, deprovisioned, or inactive for an extended period.

Step-by-Step Triage (Security Analyst View):

1. Verify the Account Status:
 - Check AD attributes: userAccountControl, lastLogonTimestamp, whenChanged.
 - Confirm the account was disabled or unused legitimately.
2. Identify the Trigger:
 - What caused the account to become active? Login, script, service, or manual enable?
 - Look for Event ID 4720 (account creation), 4722 (account enabled), or 4768/4769 (Kerberos logins).
3. Correlate with Privilege or Activity:
 - Was this account part of any privileged group?
 - Review if the account accessed sensitive files, systems, or group policy objects.
4. Look for Automation or Scripts:
 - Determine if any scheduled tasks, batch files, or service accounts attempted login.
 - Inspect systems or services that may have cached credentials.
5. Check Change Logs:
 - Review who re-enabled the account (Event ID 4722) and when.

Containment Actions:

- Disable the account immediately.
- Investigate the host or system responsible for its activation.
- Reset credentials and re-evaluate account purpose.
- Conduct IOC-based threat hunting for lateral movement.

IOCs to Look For:

Type	Example / Detail
Account Status	Account was marked disabled, yet shows successful logon
Last Activity	Last login > 90 days ago, now active
Event IDs	4722 (Enabled), 4624 (Login Success), 4768 (Kerberos TGT)
Source Host	Server/workstation initiating login using the dormant account

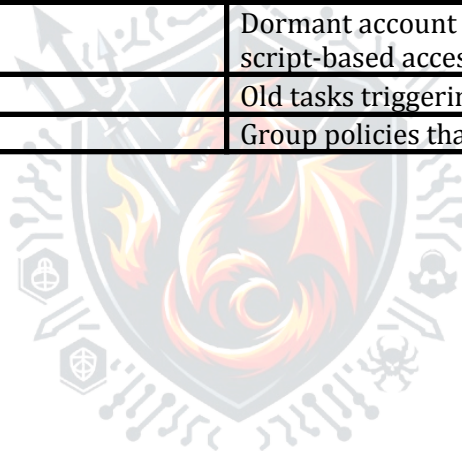
Pattern	Multiple dormant accounts reactivated in short timeframe
Privilege Level	Dormant account was previously a domain admin or service account

MITRE ATT&CK Techniques:

- T1078 – Valid Accounts
- T1531 – Account Access Removal
- T1087 – Account Discovery

Log Sources – Disabled or Dormant Account Usage

Source	Details
Windows Security Logs	Event ID 4722 (Account Enabled), 4624, 4768
Active Directory Logs	Last logon timestamp, account status attributes
SIEM	Dormant account detection and script-based access patterns
Scheduled Task Logs	Old tasks triggering account usage
GPO Audit Logs	Group policies that could re-enable users



Windows/Linux Endpoints

Case 1:

Execution of Known Malicious Processes (Detection of Suspicious Process Names or Hashes)

Step-by-Step Triage (Security Analyst View)

1. Confirm the Alert:
 - Validate the detection via endpoint security logs (e.g., Windows Event ID 4688 - process creation).
 - Cross-reference process names and hashes against threat intelligence feeds (e.g., VirusTotal, MISP, MDTI).
2. Identify Scope:
 - Pinpoint affected endpoints and users executing the suspicious processes.
 - Determine if the process was executed in privilege escalation attempts.
3. Correlation:
 - Review SIEM logs to check if similar processes ran across multiple hosts.
 - Correlate execution with additional suspicious activities (e.g., network connections, file writes).
4. Threat Intelligence Check:
 - Investigate process hashes and filenames using AbuseIPDB, VirusTotal, and CrowdStrike Falcon.
5. Check AV & EDR Enforcement:
 - Confirm whether endpoint protection (Defender ATP, CrowdStrike, SentinelOne) flagged the process.
 - Review if EDR prevented execution or quarantined the file.

Containment:

- Isolate affected endpoints from the network.
- Terminate and block execution of the malicious process.
- Delete the file and its remnants.
- Review security policies to prevent execution via AppLocker or Defender ASR Rules.

Type	Example / Detail
Process Hash	SHA256 hash matching known malware
Username	Process execution by unauthorized users
Host	Multiple endpoints running the same hash
Time-based	Execution during off-business hours
Log Result	Event ID 4688 with high-risk process
Behavior Pattern	Process making outbound connections to suspicious IPs

MITRE ATT&CK Techniques:

- T1059 – Command and Scripting Interpreter
- T1204 – Execution via User Interaction
- T1072 – Software Deployment Tools
- T1569 – System Services

Log Sources – Execution of Malicious Processes

Source	Details
Windows Event Logs	Event ID 4688 (Process Creation), 7045 (Service Installation)
Sysmon Logs	Process create, hash, command-line arguments
EDR/AV Logs	Detected malicious behavior, blocked execution
SIEM & Threat Intel	Correlation of known malicious process hashes

Case 2:

Registry Modification Alerts (Windows)

Detection Indicator: Unusual registry changes suggesting persistence techniques, such as modifications to Run keys or unauthorized startup configurations.

Step-by-Step Triage (Security Analyst View):

1. Identify Registry Modifications:
 - Monitor changes to **HKLM\Software\Microsoft\Windows\CurrentVersion\Run** and similar keys.
 - Look for modifications to **Startup** locations and auto-execution paths.
 - Review registry events in **Event ID 4657 (Registry Change)** and **Sysmon Event ID 13 (Registry Modification)**.
2. Validate Legitimacy of Changes:
 - Is the modification linked to a legitimate software install or update?
 - Are there signs of unauthorized scripts, malware droppers, or backdoors?
 - Cross-check against known registry-based persistence techniques.
3. Investigate Process Context and User Action:
 - Identify which process made the registry change (Event ID 4688 - Process Creation).
 - Check if the action was initiated by a system process, user login, or an external threat.
 - Look for suspicious **PowerShell, CMD, or WMI execution**.
4. Correlate with Host and Network Behavior:
 - Check if the system made outbound connections post-modification.
 - Review logs for **unexpected startup behaviors** or repeated changes.
 - Identify patterns of registry changes across multiple endpoints.

Containment Actions:

- **Rollback registry modifications** if malicious.
- **Terminate associated processes** and isolate affected systems.
- **Investigate the modifying entity** (script, scheduled task, malware).
- **Block unauthorized registry persistence techniques** in security policies.
- **Conduct forensic analysis** to determine potential exploitation.

IOCs to Look For:

Type	Example / Detail
Registry Path	HKLM\Software\Microsoft\Windows\CurrentVersion\Run
Modification Type	Auto-execution registry entry added
Process Source	powershell.exe, cmd.exe, reg.exe modifying keys
Network Traffic	External connections after registry changes
Pattern	Repeated registry modifications on multiple machines

MITRE ATT&CK Techniques:

- **T1547.001** – Registry Run Keys / Startup Folder
- **T1112** – Modify Registry
- **T1037** – Scheduled Task / Startup Execution

Log Sources – Registry Modification Alerts

Source	Details
Windows Security Logs	Event ID 4657 (Registry Modification)
Sysmon Logs	Event ID 13 (Registry Change), Event ID 1 (Process Creation)
EDR/AV Logs	Detection of registry-based persistence techniques
SIEM & Threat Intel	Correlation of unusual registry modifications

Case : 3

Unusual PowerShell or Command Line Usage

Detection Indicator: Execution of encoded, obfuscated, or excessively long command-line inputs, suggesting potential malware or attacker activity.

Step-by-Step Triage (Security Analyst View):

1. Identify Suspicious PowerShell or CMD Execution:
 - Look for **Event ID 4688 (Process Creation)** to trace execution source.
 - Check for **PowerShell logging (Event ID 4104 - Script Block Logging)**.
 - Analyze command-line inputs for signs of **Base64 encoding**, obfuscation, or excessive length.
2. Decode Encoded or Obfuscated Strings:
 - Base64-encoded commands (`powershell.exe -Enc [Base64String]`).
 - Hex, XOR, or ROT13 obfuscation in scripts.
 - Use decoding tools to **extract plaintext command logic**.
3. Investigate Execution Context and Parent Process:
 - Was the command executed **interactively**, by a **script**, or within a **scheduled task**?
 - Look for **unexpected parent-child relationships** (e.g., `winword.exe` spawning PowerShell).
 - Identify whether execution occurred **remotely (via PsExec, WMI, or PowerShell Remoting)**.
4. Correlate with Network and Host Activity:
 - **Check for outbound connections** post-command execution.
 - **Look for script downloads** (e.g., `Invoke-WebRequest`, `bitsadmin.exe` fetching payloads).
 - Review logs for **persistence mechanisms**, such as **modifications to startup entries**.

Containment Actions:

- **Terminate suspicious PowerShell or CMD processes** immediately.
- **Isolate affected host** and investigate execution source.
- **Block commonly abused PowerShell techniques** (e.g., constrained mode or logging enforcement).
- **Check for lateral movement** attempts across multiple endpoints.
- **Hunt for similar encoded or obfuscated execution attempts** within logs.

IOCs to Look For:

Type	Example / Detail
Command Line	Base64-encoded PowerShell execution
Process Behavior	PowerShell executed from unexpected parent process (e.g., <code>svchost.exe</code>)
Network Activity	Unusual outbound traffic after PowerShell execution
Remote Execution	PowerShell remoting or PsExec used
Pattern	Multiple hosts executing obfuscated PowerShell scripts

MITRE ATT&CK Techniques:

- **T1059.001** – PowerShell Abuse
- **T1027** – Obfuscation
- **T1072** – Remote Execution Tools
- **T1086** – Command Execution via PowerShell

Log Sources – Unusual PowerShell or Command Line Usage

Source	Details
Windows Event Logs	Event ID 4688 (Process Creation), 4104 (Script Block Logging)
Sysmon Logs	Event ID 1 (Process Create), 13 (Registry Changes)
EDR/AV Logs	Detection of encoded or obfuscated scripts
SIEM & Threat Intel	Identification of PowerShell execution anomalies

Case 4:

Unsigned Binary or LOLBins Execution

Detection Indicator: Execution of living-off-the-land binaries (LOLBins) such as `mshta.exe`, `certutil.exe`, `wmic.exe`, or other unsigned binaries often abused by attackers.

Step-by-Step Triage (Security Analyst View):

1. Identify LOLBin Execution Events:
 - Look for **Event ID 4688 (Process Creation)** to trace execution source.
 - Check **Sysmon Event ID 1** for command-line arguments related to LOLBins.
 - Monitor usage of `mshta.exe`, `regsvr32.exe`, `wmic.exe`, `certutil.exe`, `rundll32.exe`.
2. Analyze Execution Context and Parent Process:
 - Was the binary executed **by a user, a script, or an external process?**
 - Identify unusual parent-child relationships (e.g., `winword.exe` spawning `mshta.exe`).
 - Look for **PowerShell, CMD, or WMI invoking LOLBins**.
3. Investigate Command-Line Arguments and Execution Patterns:
 - Review command parameters (e.g., `certutil.exe -urlcache -split -f <URL>` used to download files).
 - Look for **encoded or obfuscated commands**.
 - Identify **use of DLL injection or reflective execution methods**.
4. **Correlate Network and Host Activity:**
 - **Check for outbound C2 connections** following execution.
 - Identify if the process accessed sensitive files or registry keys.
 - Review logs for **persistence mechanisms** like **scheduled tasks or registry modifications**.

Containment Actions:

- **Terminate and block the execution of known LOLBins** when unauthorized.
- **Investigate parent processes** and identify sources of execution.
- **Apply least privilege policies** to prevent execution of abuse-prone binaries.
- **Harden system configurations** to restrict LOLBins abuse.
- **Conduct forensic analysis** on affected hosts and **hunt for lateral movement**.

IOCs to Look For:

Type	Example / Detail
LOLBin Executed	<code>mshta.exe</code> , <code>wmic.exe</code> , <code>regsvr32.exe</code>
Process Behavior	LOLBin executing scripts or connecting externally
Network Activity	<code>certutil.exe</code> fetching files from a rare domain
Remote Execution	<code>wmic.exe</code> used for remote system interaction
Pattern	Multiple endpoints executing similar LOLBin abuse

MITRE ATT&CK Techniques:

- **T1218** – Signed Binary Proxy Execution
- **T1205** – Traffic Signaling via LOLBins
- **T1072** – Remote Execution Tools
- **T1086** – PowerShell and CMD Abuse

Log Sources – Unsigned Binary or LOLBins Execution

Source	Details
Windows Event Logs	Event ID 4688 (Process Creation), 7045 (Service Installation)
Sysmon Logs	Process create, command-line arguments
EDR/AV Logs	Detection of LOLBin abuse and behavior anomalies
SIEM & Threat Intel	Correlation of execution patterns across hosts

Email Security

Case 1:

Phishing Attempt Detection

Detection Indicator: Emails containing suspicious sender domains, spoofed headers, or links leading to malicious websites, often used to steal credentials or deliver malware.

Step-by-Step Triage (Security Analyst View):

1. Inspect Sender and Domain Reputation:
 - Verify sender domain legitimacy (check SPF, DKIM, and DMARC records).
 - Identify **lookalike domains** (e.g., `micros0ft.com` instead of `microsoft.com`).
 - Review email headers for signs of **spoofing or impersonation attempts**.
2. Analyze Email Content and Links:
 - Look for **urgent language** pressuring the user to act quickly.
 - Identify **malformed links** (e.g., hidden behind buttons or disguised URLs).
 - Examine link behavior using URL sandboxes (VirusTotal, Cisco Umbrella, etc.).
3. Check Attachments for Malicious Payloads:
 - Review file extensions (**.exe, .scr, .zip, .docm**) for potential malware.
 - Examine VBA macros or embedded scripts in **Office documents and PDFs**.
 - Use **hash-based detection** and scan file reputation databases.
4. Correlate with User Interaction and External Reports:
 - Determine if **users clicked links or downloaded attachments**.
 - Identify if multiple employees received similar phishing emails.
 - Check if the email **originates from previously blacklisted sources**.

Containment Actions:

- **Block the sender domain** and mark emails as phishing.
- **Warn affected users** and conduct security awareness training.
- **Disable accounts if credentials were compromised** and enforce password resets.
- **Analyze email infrastructure logs** for widespread attack patterns.
- **Perform retroactive IOC-based threat hunting** to identify related phishing attempts.

IOCs to Look For:

Type	Example / Detail
Suspicious Domain	<code>micros0ft.com</code> , <code>secure-bank-login.xyz</code>
Sender Address	Display name mismatch (e.g., <code>CEO@company.com</code> but actual domain is unknown)
Malicious Link	Embedded URLs leading to phishing sites
Attachments	<code>.zip</code> , <code>.docm</code> , <code>.pdf</code> containing hidden scripts
Geographic Mismatch	Sender IP from unexpected country or known threat actor region

MITRE ATT&CK Techniques:

- **T1566.001** – Spearphishing Link
- **T1566.002** – Spearphishing Attachment
- **T1071** – Application Layer Protocol (C2 Communications)
- **T1204** – Execution via User Interaction

Log Sources – Phishing Attempt Detection

Source	Details
Email Security Logs	Header analysis, sender domain verification
SIEM & Threat Intelligence	Correlation of phishing attempts across users
Web Proxy Logs	User interactions with phishing links
EDR/AV Logs	Detection of payload execution from phishing emails

Case 2:

Malware in Attachments

Detection Indicator: Suspicious files delivered via email, messaging apps, or file-sharing platforms, potentially containing malware, macros, or exploit payloads.

Step-by-Step Triage (Security Analyst View):

1. Identify Suspicious File Attachments:
 - Review **file extensions** (.exe, .dll, .scr, .vbs, .docm, .zip).
 - Look for **macro-enabled Office files**, hidden scripts, or packed executables.
 - Verify if the attachment **bypassed default security controls**.
2. Perform Sandbox Analysis and Dynamic Execution:
 - Detonate the file in an **isolated sandbox environment**.
 - Monitor runtime behavior for **process creation, registry changes, network connections**.
 - Observe **attempts to download additional payloads** or modify system files.
3. Check File Hash Reputation and Static Analysis:
 - Use **VirusTotal, Hybrid-Analysis, or other threat intelligence sources**.
 - Analyze hashes against known malware signatures.
 - Inspect embedded VBA macros or obfuscated PowerShell commands.
4. Correlate Email and Endpoint Activity:
 - **Trace sender domain and email headers** for signs of phishing or spoofing.
 - Determine if **users interacted with the attachment** or executed its contents.
 - Identify whether the malware **has affected multiple endpoints**.

Containment Actions:

- **Block malicious attachments** and flag suspicious emails.
- **Quarantine affected endpoints** and restricted access.
- **Reverse-engineer malware behavior** to understand its impact.
- **Implement attachment scanning policies** across security infrastructure.
- **Perform retroactive threat hunting** for indicators of compromise (IOCs).

IOCs to Look For:

Type	Example / Detail
File Extension	.exe, .docm, .vbs, .zip

File Hash	Matches known malware in threat intel databases
Embedded Scripts	VBA macros, PowerShell payloads inside Office documents
Network Traffic	Attachment attempting external connections
Pattern	Similar attachments sent to multiple users

MITRE ATT&CK Techniques:

- **T1566.001** – Spearphishing Attachment
- **T1204** – User Execution
- **T1059.005** – Command Execution via Script Files
- **T1071** – Application Layer Protocol (C2 Communications)

Log Sources – Malware in Attachments

Source	Details
Email Security Logs	Attachment scanning, domain reputation verification
EDR & AV Logs	Malware detection via endpoint security
SIEM & Threat Intelligence	Cross-correlation of malicious attachment indicators
Sandbox Analysis Reports	Dynamic execution insights

Case 3:

Business Email Compromise (BEC)

Detection Indicator: Fraudulent emails impersonating executives or trusted entities, requesting urgent money transfers, invoice payments, or sensitive financial transactions.

Step-by-Step Triage (Security Analyst View):

1. Verify Sender Identity and Email Headers:
 - Analyze **sender domain and display name mismatches**.
 - Check **spoofed headers**, including **Return-Path** and **Reply-To** inconsistencies.
 - Review **SPF, DKIM, and DMARC** records for email authenticity.
2. Analyze Email Content for Social Engineering Techniques:
 - Look for **urgent requests** with a strong emotional appeal.
 - Identify **requests for wire transfers or invoice modifications**.
 - Review grammar, tone, and formatting irregularities that mimic executives.
3. Check Links and Attachments for Malicious Indicators:
 - Inspect embedded **links redirecting to credential-harvesting sites**.
 - Scan attachments for **macro-enabled files, invoice PDFs, or financial documents**.
 - Validate if **URLs match legitimate business domains**.
4. Correlate With Previous Incidents and External Reports:
 - Determine if similar **BEC attempts targeted multiple employees**.
 - Investigate prior successful fraud attempts within the organization.
 - Check financial systems for **unauthorized payment requests**.

Containment Actions:

- **Flag and block emails from spoofed domains.**
- **Alert finance teams** to prevent unauthorized transactions.
- **Educate employees on recognizing BEC scams** through awareness training.
- **Investigate compromised accounts** that may have been used for internal phishing.
- **Perform retroactive IOC-based threat hunting** on affected systems.

IOCs to Look For:

Type	Example / Detail
Fake Executive Email	CEO@CompanyFinance.co instead of CEO@Company.com

Display Name Spoof	Looks like a legitimate sender but uses a fraudulent domain
Payment Request	Urgent wire transfers to unknown bank accounts
Malicious Attachment	Fake invoices with embedded malware
Suspicious Link	Phishing pages impersonating business login portals

MITRE ATT&CK Techniques:

- **T1566.002** – Spear Phishing via Email Impersonation
- **T1598.003** – Social Engineering Fraud (BEC Scams)
- **T1071** – Application Layer Protocol (C2 via Email)
- **T1204** – Execution via User Interaction

Log Sources – Business Email Compromise (BEC) Detection

Source	Details
Email Security Logs	Header analysis, sender authentication failures
SIEM & Threat Intelligence	Cross-correlation of phishing attempts
Financial Transaction Logs	Unusual wire transfer requests
Web Proxy Logs	Employees clicking on phishing links

Endpoint Detection & Response (EDR)

Case 1:

Lateral Movement Detection

Detection Indicator: Identification of tools and techniques used by attackers to move across internal systems, such as PsExec, Remote Desktop Protocol (RDP), WMI, SMB, or PowerShell remoting.

Step-by-Step Triage (Security Analyst View):

1. Identify Unusual Remote Execution Events:
 - Monitor **Event ID 5145 (SMB File Access)** for network traversal attempts.
 - Check **Event ID 4624 (Logon Success)** for RDP logins across multiple systems.
 - Review **Sysmon Event ID 1 (Process Creation)** for execution of lateral movement tools (`psexec.exe`, `wmic.exe`, `rundll32.exe`).
2. Analyze Authentication and Privilege Escalation Attempts:
 - Look for **Event ID 4672 (Special Privileges Assigned)** linked to suspicious logins.
 - Identify **multiple failed authentication attempts** across endpoints.
 - Monitor **Event ID 4769 (Kerberos TGT Requests)** for service ticket requests from unexpected users.
3. Investigate Network and Host Activity:
 - Correlate **process execution with outbound connections** to other systems.
 - Look for **PowerShell remoting or remote service execution attempts**.
 - Review logs for **unexpected SMB file transfers or remote registry modifications**.
4. Correlate with Known Attack Patterns:
 - Analyze historical **use of PsExec, RDP, or WMI in prior incidents**.
 - Check whether the activity **matches known adversary techniques** from threat intelligence reports.
 - Look for **repeat execution patterns across multiple hosts or accounts**.

Containment Actions:

- **Isolate affected hosts** and disable unauthorized remote access.
- **Audit privilege assignments** for accounts exhibiting unusual lateral movement.
- **Block execution of lateral movement tools** where possible.
- **Perform retroactive threat hunting** to identify similar behavior across logs.

- **Implement network segmentation** to limit unnecessary remote access pathways.

IOCs to Look For:

Type	Example / Detail
Remote Execution Tool	<code>psexec.exe</code> , <code>wmic.exe</code> , <code>rundll32.exe</code> abuse
Unexpected Logins	RDP connections outside normal usage patterns
Privilege Escalation	User granted administrative privileges unexpectedly
Network Traffic	SMB file access across multiple machines
Pattern	Multiple endpoints accessed by the same suspicious account

MITRE ATT&CK Techniques:

- **T1570** – Lateral Tool Transfer
- **T1077** – Windows Admin Shares Abuse
- **T1021.001** – Remote Desktop Protocol (RDP)
- **T1569.002** – Remote Services Execution

Log Sources – Lateral Movement Detection

Source	Details
Windows Security Logs	Event ID 4624 (Logon Success), 5145 (SMB Access)
Sysmon Logs	Event ID 1 (Process Creation), Event ID 3 (Network Connection)
SIEM & Threat Intel	Correlation of remote execution attempts

Endpoint Detection Logs	Identification of abuse of administrative tools
--------------------------------	---

Case 2:

Persistence Mechanism Indicators

Detection Indicator: Identification of scheduled tasks, services, registry modifications, or startup folder usage that adversaries leverage for maintaining long-term access.

Step-by-Step Triage (Security Analyst View):

1. Identify Scheduled Tasks and Autorun Entries:
 - Monitor **Event ID 4698 (Scheduled Task Creation)** for suspicious entries.
 - Review **Task Scheduler logs** for unauthorized modifications.
 - Check common persistence locations such as **HKLM\Software\Microsoft\Windows\CurrentVersion\Run**.
2. Analyze Service Creation and Modifications:
 - Look for **Event ID 7045 (New Service Installed)**.
 - Identify **hidden or unexpected services** running on startup.
 - Correlate services executing **non-standard binaries or PowerShell scripts**.
3. Investigate Startup Folder Abuse:
 - Check system startup folders for **newly added executables or scripts**.
 - Review **Sysmon Event ID 1 (Process Creation)** for execution via startup mechanisms.
 - Look for **unexpected registry changes linked to autorun settings**.
4. Correlate with Other Indicators of Compromise:
 - Analyze persistence **patterns across multiple systems**.
 - Identify **user accounts associated with the modifications**.
 - Look for **additional privilege escalation attempts** connected to persistence.

Containment Actions:

- **Disable unauthorized scheduled tasks and services.**
- **Rollback persistence-related registry modifications.**
- **Quarantine affected systems for deeper forensic analysis.**
- **Review system-wide startup configurations** for anomalies.
- **Conduct proactive threat hunting** to uncover related persistence mechanisms.

IOCs to Look For:

Type	Example / Detail
Scheduled Task	Hidden scheduled job executing malicious payload
Autorun Registry Change	Unexpected modification of HKLM\Software\Microsoft\Windows\CurrentVersion\Run
New Service Installed	Uncommon service registered to execute stealth malware
Network Traffic	Persistence mechanisms leading to external communication
Pattern	Multiple machines exhibiting similar persistence methods

MITRE ATT&CK Techniques:

- **T1053** – Scheduled Task / Job Abuse
- **T1547** – Boot or Logon Autostart Execution
- **T1569.002** – Service Execution for Persistence
- **T1070** – Indicator Removal on Host

Log Sources – Persistence Mechanism Detection

Source	Details
Windows Security Logs	Event ID 4698 (Scheduled Task), 7045 (Service Install)
Sysmon Logs	Event ID 1 (Process Creation), 13 (Registry Modification)
SIEM & Threat Intelligence	Cross-correlation of persistent execution attempts

Endpoint Detection Logs	Behavioral anomaly detection for persistence techniques
--------------------------------	---

Case 3:

Execution of Credential Dumping Tools

Detection Indicator: Identification of Mimikatz, LSASS memory dumping, NTLM hash extraction, or other techniques used to steal credentials from compromised systems.

Step-by-Step Triage (Security Analyst View):

1. Identify Suspicious Process Creation:
 - Monitor **Event ID 4688 (Process Creation)** for execution of `mimikatz.exe`, `procdump.exe`, or similar tools.
 - Review **Sysmon Event ID 1 (Process Creation)** for unusual command-line arguments related to credential dumping.
 - Look for **NTLM hash extraction attempts** using `lsass.exe` memory dumps.
2. Analyze LSASS Memory Access and Tampering:
 - Check **Event ID 10 (Sysmon Process Access)** for attempts to read LSASS memory.
 - Investigate use of `procdump.exe` or other dumping tools targeting `lsass.exe`.
 - Identify **direct SYSTEM-level execution** to access protected credential stores.
3. Correlate with Authentication Logs and Privilege Escalation:
 - Look for **Event ID 4624 (Logon Success)** followed by credential dumping activity.
 - Identify **Event ID 4672 (Special Privileges Assigned)** to newly logged-in accounts.
 - Examine **multiple failed authentication attempts** within a short time frame.
4. Investigate Network and Host Activity Post-Credential Dumping:
 - Check for **lateral movement attempts** using stolen credentials.
 - Identify **Event ID 4769 (Kerberos TGT Requests)** for privilege escalation efforts.
 - Look for **C2 connections or external data exfiltration** after credential theft.

Containment Actions:

- **Terminate suspicious processes immediately** to prevent further credential theft.
- **Isolate affected systems** for forensic analysis and memory dump inspection.

- **Reset compromised passwords** and enforce MFA where applicable.
- **Harden LSASS protections** to prevent unauthorized memory dumps.
- **Perform proactive threat hunting** for past credential dumping attempts.

IOCs to Look For:

Type	Example / Detail
Process Name	<code>mimikatz.exe</code> , <code>procdump.exe</code> , <code>lsassy.py</code>
Memory Access	LSASS memory read attempts (Sysmon Event ID 10)
Authentication Behavior	Privilege escalation attempts post-dump
Network Traffic	External connections after credential theft
Pattern	Multiple credential dumps across domain-joined endpoints

MITRE ATT&CK Techniques:

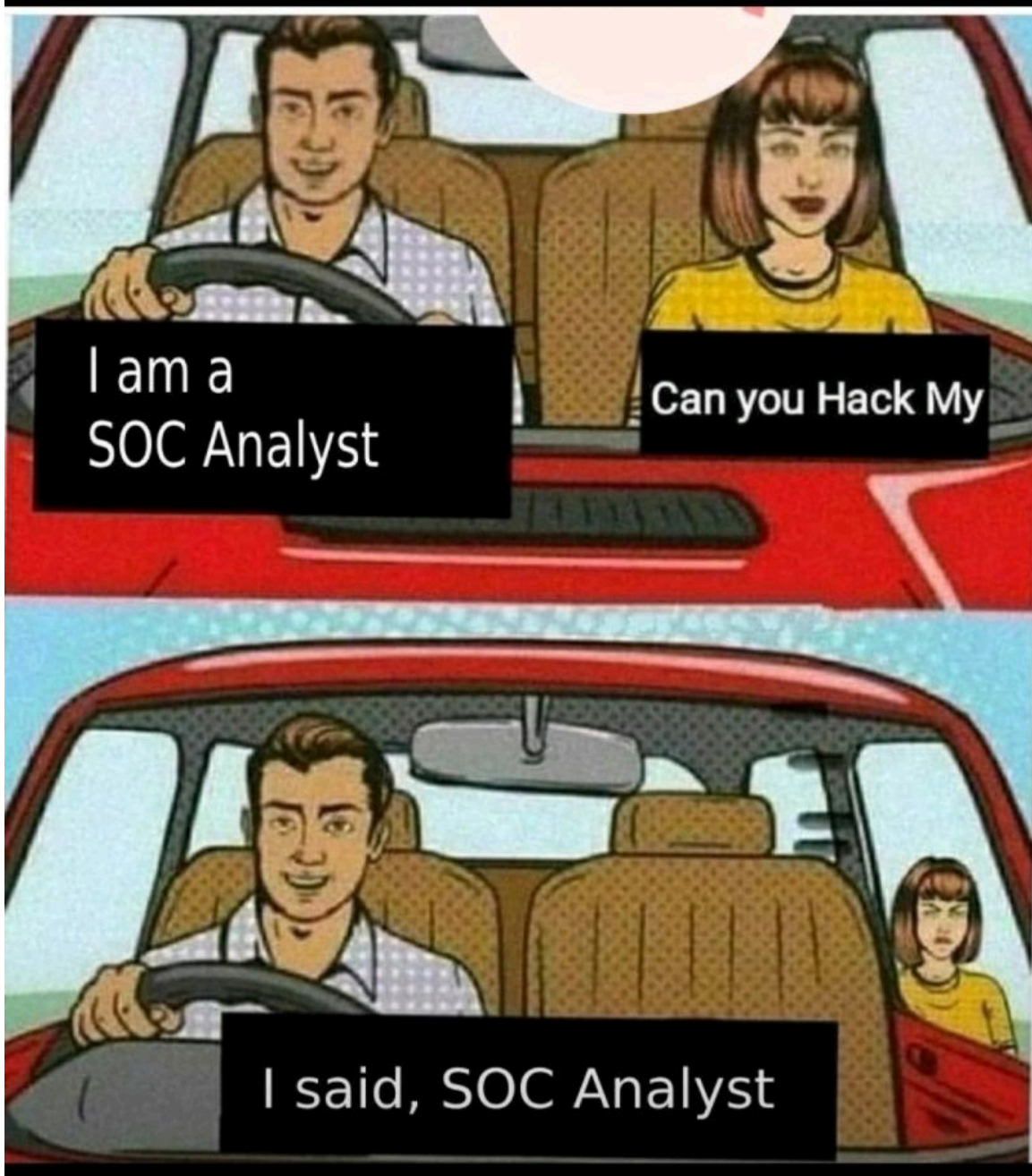
- **T1003** – OS Credential Dumping
- **T1555** – Credential Storage Extraction
- **T1078** – Valid Accounts Abuse
- **T1071** – Command and Control via Stolen Credentials

Log Sources – Execution of Credential Dumping Tools

Source	Details
Windows Security Logs	Event ID 4624 (Logon Success), 4672 (Privilege Escalation)
Sysmon Logs	Event ID 1 (Process Creation), 10 (LSASS Memory Access)
SIEM & Threat Intelligence	Cross-correlation of credential theft behavior

Endpoint Detection Logs	Detection of LSASS dumps and unauthorized memory access
--------------------------------	---





Thank You

